

Security Technology: Intrusion Detection and Prevention System

Intrusion Detection Systems

- **Intrusion Detection Systems**

- An intrusion detection system **attempts to detect an intruder breaking into your system or an authorized user misusing system resources.**
- The IDS operate constantly on your system, working in the background.
- There are **two major classifications of potential intruders:**
 - **Outside Intruders**
 - **Inside Intruders**

- **An intrusion is defined as any set of actions that attempt to compromise the**
 - **Integrity**
 - **Confidentiality**
 - **Availability****of a resources.**

Intrusion Prevention Systems

- **Intrusion Prevention Systems**

- An Intrusion Prevention System (IPS) actively monitors network and system traffic to detect and block malicious activity in real time.
- It extends traditional IDS capabilities by not only identifying threats but also automatically preventing attacks before they cause damage.
 - Detects and blocks malicious traffic instantly
 - Monitors network and host activities continuously
 - Uses signatures, behavior, and anomaly analysis
 - Prevents intrusions through automated responses
 - Enhances security visibility and reduces attack impact

Definitions

- **Intrusion detection:** is the process of monitoring the events occurring in a computer system or network and analyzing them for signs of possible *intrusions (incidents)*.
- **Intrusion detection system (IDS):** is software that automates the intrusion detection process. The primary responsibility of an IDS is to detect unwanted and malicious activities.
- **Intrusion prevention system (IPS):** is software that has all the capabilities of an intrusion detection system and can also attempt to stop possible incidents.

Intrusion Detection and Prevention Systems (IDPS)

- An Intrusion Detection and Prevention System (IDPS) is a security mechanism that continuously monitors network traffic, system activities, and user behavior to identify malicious actions, policy violations, or security breaches.
 - Intrusion Detection System (IDS): Detects and alerts
 - Intrusion Prevention System (IPS): Detects and actively blocks threats

IDPS Terminology

- **Alert** : An alert is a warning generated by the IDPS to inform security staff about suspicious activity. Alerts can be in the form of sound, email, message, or pop-up.

Example: An email alert is sent to the administrator when multiple login failures occur.

- **Evasion** : Evasion is a technique used by attackers to change the attack pattern so that the IDPS cannot detect it.

Example: A hacker slightly changes malicious code to bypass IDPS detection.

- **Noise** : Noise refers to alerts that are correct but not dangerous and do not require action.

Example: Repeated failed login attempts by a user who forgot their password.

- **False Positive** : A false positive happens when the IDPS raises an alert for normal or harmless activity.

Example: A user downloading a large file is mistakenly flagged as a data theft attempt.

- **False Negative** : A false negative occurs when the IDPS fails to detect a real attack.

Example: A new malware attack enters the system but the IDPS does not generate any alert.

- **False Attack Stimulus** : This occurs when an event triggers an alert even though no real attack is happening.

Example: A system update generates traffic that triggers an alert even though it is safe.

→ *False Positive = Alert without attack*

→ *False Negative = Attack without alert*

- **Alarm Filtering** : Alarm filtering is the process of classifying and filtering IDPS alerts so that only important and relevant alerts are shown. It helps security staff manage alerts more efficiently.

Example: An IDPS filters alerts to show only high-confidence attacks from external IP addresses, ignoring low-risk internal alerts.

- **Alarm Clustering and Compaction** : Alarm clustering and compaction means grouping similar alerts that occur within a short time into a single, higher-level alert. This reduces the total number of alerts generated.

Example: Hundreds of login failure alerts from the same IP are combined into one “brute-force attack” alert.

- Alarm Filtering → Removes unnecessary alerts
- Alarm Clustering → Groups similar alerts into one

Why Use an IDPS?

- **Early Threat Detection** – Identify malicious activity such as malware, zero-day exploits, or unusual user behavior before it spreads.
- **Automated Prevention** – Block attacks in real time, minimizing downtime and ensuring business continuity.
- **Regulatory Compliance** – Meet requirements for frameworks like GDPR, HIPAA, and PCI-DSS by demonstrating strong security controls.
- **Reduced Costs** – Preventing breaches is far less costly than remediation, legal fines, or customer trust loss.
- **24/7 Security Monitoring** – Ensure continuous protection against both internal and external threats.

Types of IDPS

IDPS can be classified based on where they are deployed and what they monitor.

- Network-Based IDPS (NIDPS)
- Host-Based IDPS (HIDPS)
- Wireless IDPS (WIDPS)
- Network Behavior Analysis (NBA) IDPS

Network-Based IDPS (NIDPS)

- A Network-based IDPS monitors network traffic across network segments and analyzes packets to detect suspicious activity. It is usually deployed at network boundaries such as firewalls or gateways.
- **Benefits**
 - Provides wide network visibility
 - Detects many types of network attacks
 - Protects multiple systems at once
- **Challenges**
 - Can be overloaded by high traffic volumes
 - Cannot fully inspect encrypted traffic
 - Limited visibility into host-level activities

Example: Detects a port-scanning attack at the company's firewall.

Host-Based IDPS (HIDPS)

- A Host-based IDPS monitors activities inside a specific system, such as logs, processes, file changes, and application behavior. It is installed on critical hosts.
- **Benefits**
 - Provides detailed host-level monitoring
 - Can detect insider attacks
 - Can inspect encrypted data on the host
- **Challenges**
 - Uses system resources
 - Requires installation and management on each host
 - If the host is compromised, IDS may also be affected

Example: Detects unauthorized changes to system configuration files on a server.

Wireless IDPS (WIDPS)

- A Wireless IDPS monitors wireless traffic and radio frequencies to detect threats in Wi-Fi networks. It focuses only on wireless communication.
- **Benefits**
 - Detects rogue access points
 - Prevents unauthorized wireless access
 - Improves wireless network security
- **Challenges**
 - Limited to wireless protocols only
 - Coverage depends on sensor placement
 - Cannot analyze application-level attacks

Example: Detects an unauthorized Wi-Fi hotspot within office premises.

Network Behavior Analysis (NBA) System

- NBA systems analyze network traffic behavior and flow patterns to detect unusual activities instead of known signatures.
- **Benefits**
 - Effective against DDoS and data exfiltration
 - Detects unknown and zero-day attacks
 - Useful for internal threat detection
- **Challenges**
 - Requires time to build a baseline
 - May generate false positives
 - Needs regular tuning

Example: Detects unusual large data transfers outside business hours.

Comparison of IDPS Types

Type of IDPS	What it Monitors	Deployment Location	Benefits	Challenges
Network-based IDPS (NIDPS)	Network traffic and packets	Network boundaries (firewalls, gateways)	Broad network visibility, detects many network attacks, protects multiple systems	Cannot inspect encrypted traffic, high traffic load, limited host visibility
Host-based IDPS (HIDPS)	System logs, files, processes, applications	Individual hosts (servers, endpoints)	Detailed host monitoring, detects insider attacks, sees encrypted data	Resource-intensive, needs installation on every host, can be compromised if host is hacked
Wireless IDPS (WIDPS)	Wireless traffic and radio frequencies	Within wireless network range	Detects rogue access points, prevents unauthorized Wi-Fi access	Limited to wireless protocols, coverage issues, cannot detect application-level attacks
Network Behavior Analysis (NBA)	Network traffic behavior and flow patterns	Internal and external networks	Detects unknown and zero-day attacks, effective for DDoS detection	Requires baseline creation, higher false positives, needs tuning

IDPS Detection Methods

- Intrusion Detection and Prevention Systems (IDPS) use different detection methods to identify malicious activities in a network or system. The three main detection methods are
 - Signature-Based Detection,
 - Anomaly-Based Detection, and
 - Stateful Protocol Analysis.

Signature-Based Detection

- Signature-based detection works by comparing observed activities against a database of known attack patterns, called signatures.
- **Working**
 - Incoming network traffic or system activity is monitored.
 - The IDPS compares this activity with stored attack signatures.
 - If a match is found, the IDPS raises an alert or blocks the activity.
- **Advantages**
 - Highly accurate for known attacks
 - Low false-positive rate
 - Easy to understand and configure
 - Fast response time
- **Disadvantages**
 - Cannot detect unknown or zero-day attacks
 - Requires frequent updates of signature database
 - Ineffective against slightly modified attacks

- **Applications**
 - Firewalls
 - Antivirus software
 - Web application security systems
- **Example**
 - A known SQL injection pattern is detected when a user enters malicious SQL code in a login form, and the IDPS blocks the request.

Anomaly-Based Detection

- Anomaly-based detection identifies attacks by detecting deviations from normal behavior. The system learns what normal activity looks like and flags anything unusual.
- **Working**
 - The IDPS establishes a baseline of normal system or network behavior.
 - Current activity is continuously compared to this baseline.
 - Any significant deviation triggers an alert.
- **Advantages**
 - Can detect unknown and zero-day attacks
 - Effective against insider threats
 - Adaptive to changing environments
- **Disadvantages**
 - High false-positive rate
 - Time-consuming to build a baseline
 - Requires regular tuning and monitoring

- **Applications**

- Enterprise networks
- Data centers
- High-security environments

- **Example**

- An employee normally accesses a few files daily but suddenly downloads thousands of files late at night. The IDPS flags this as suspicious behavior.

Stateful Protocol Analysis

- Stateful protocol analysis examines network protocols and checks whether communication follows valid protocol states and standards.
- **Working**
 - The IDPS understands how protocols should behave.
 - It tracks the state of protocol communications.
 - Traffic that violates protocol rules is flagged as suspicious.
- **Advantages**
 - Detects protocol-level attacks
 - More accurate than simple packet inspection
 - Effective against malformed packet attacks
- **Disadvantages**
 - Resource-intensive
 - Requires up-to-date protocol definitions
 - Complex to configure

- **Applications**
 - Financial systems
 - Critical infrastructure networks
 - Secure enterprise environments
- **Example**
 - The IDPS detects malformed TCP packets that do not follow standard TCP handshake rules, indicating a possible attack.

Strengths of IDPSs

- IDPSs provide **real-time monitoring and detection** of security threats.
- They can **automatically block or prevent attacks** when deployed as IPS.
- IDPSs improve **visibility into network and system activities** through logs and alerts.
- They are capable of detecting **both known attacks and abnormal behavior**.
- IDPSs support **incident response and forensic investigations** by maintaining detailed records.
- They help in **enforcing organizational security policies**.

Limitations of IDPSs

- IDPSs may generate **false positives**, where normal activities are flagged as attacks.
- They may also produce **false negatives**, failing to detect some real attacks.
- IDPSs have **limited ability to inspect encrypted traffic**.
- Inline IPS deployment can **impact network performance**.
- IDPSs require **regular updates, tuning, and monitoring** to remain effective.
- IDPSs **cannot function as a standalone security solution** and must be used with other controls.

Deployment And Implementation of an IDPS

- An IDPS can be implemented via one of three basic control strategies:
 - **Centralized:** All IDPS control functions are implemented and managed in a central location.
 - **Fully distributed:** All control functions are applied at the physical location of each IDPS component.
 - **Partially distributed:** Combines the two; while individual agents can still analyze and respond to local threats, they report to a hierarchical central facility to enable organization to detect widespread attacks.

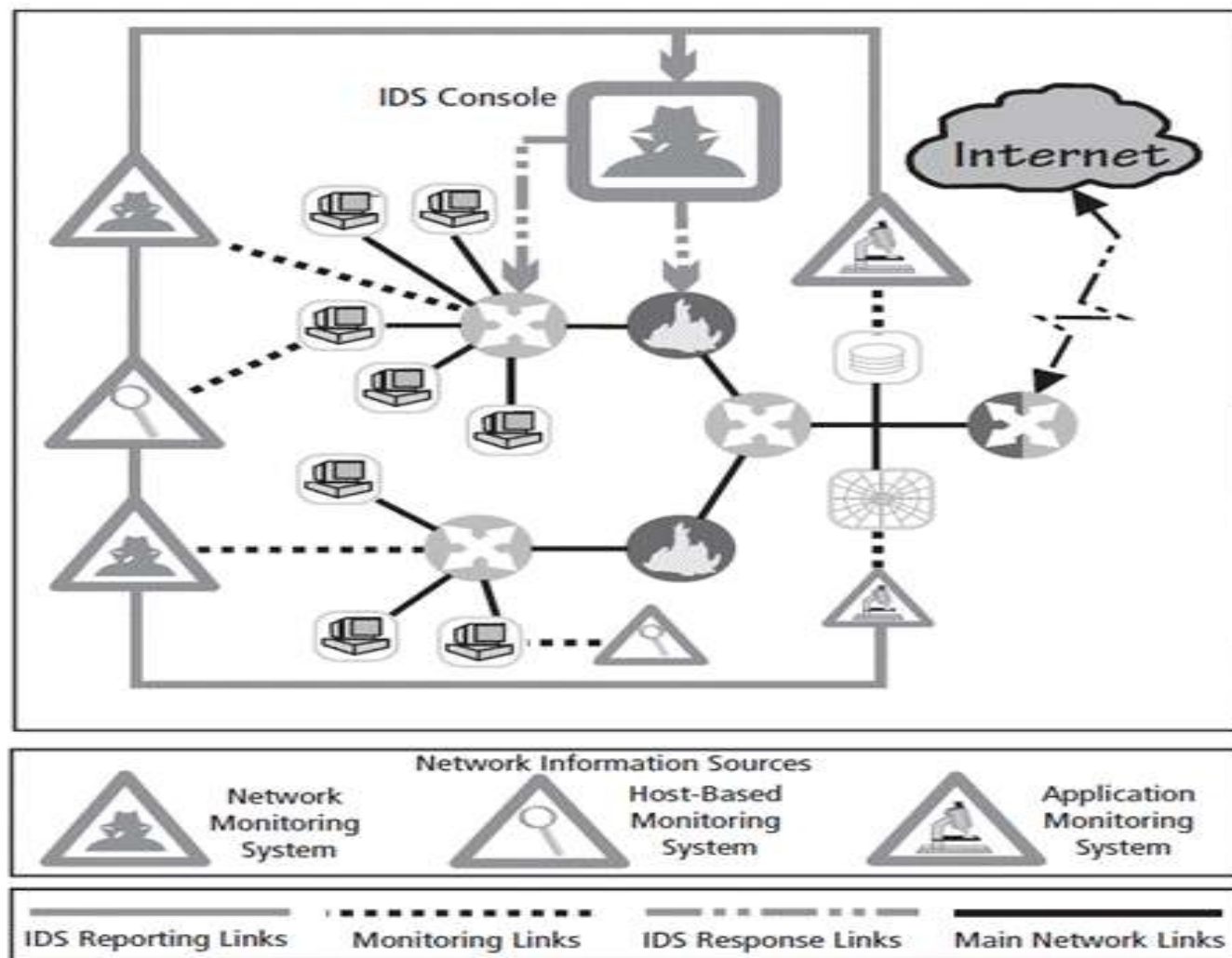


Figure 7-4 Centralized IDPS control²⁰

Source: Adapted from Scarfone and Mell, NIST SP 800-94.

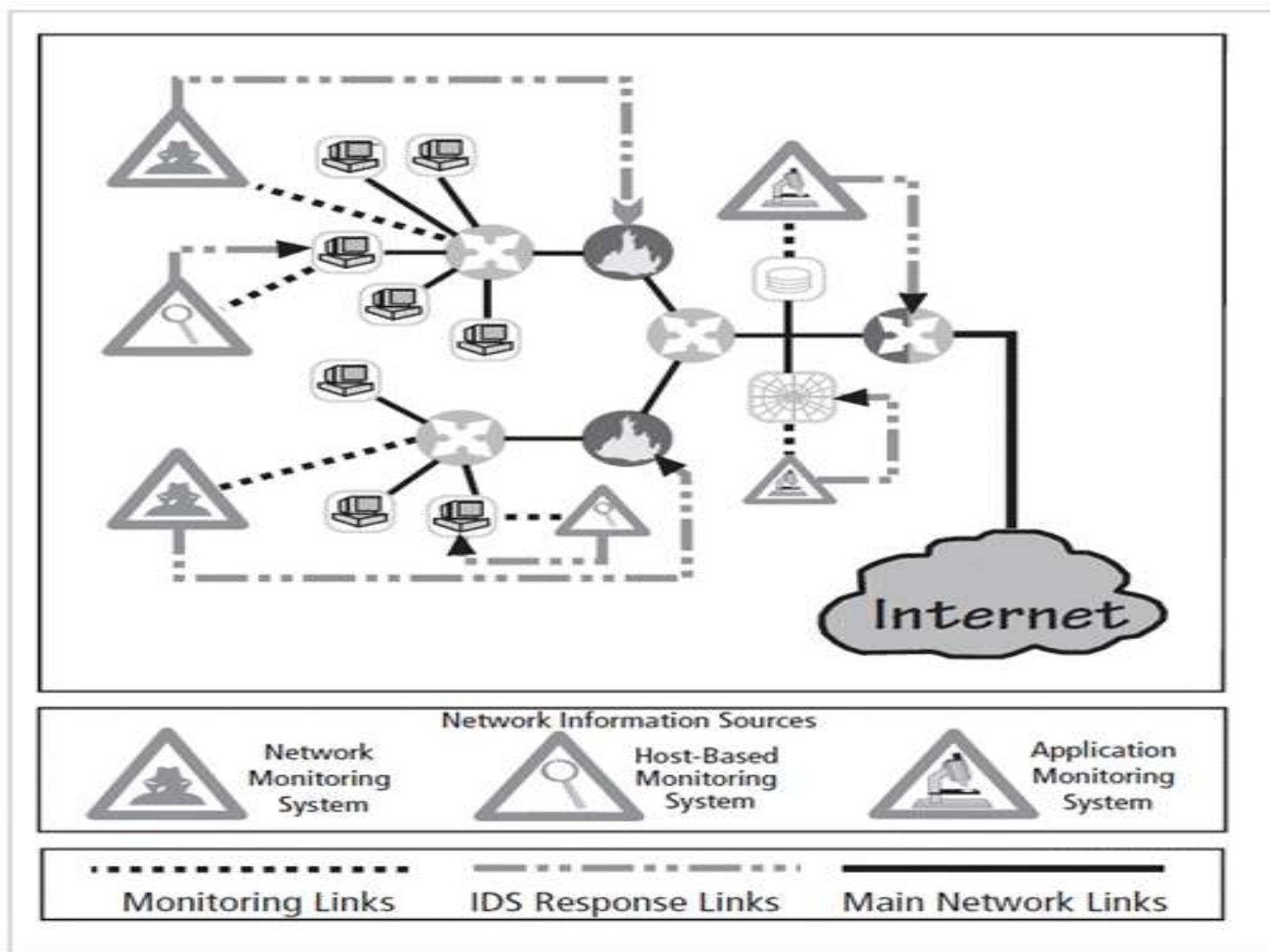


Figure 7-5 Fully distributed IDPS control²¹

Source: Adapted from Scarfone and Mell, NIST SP 800-94.

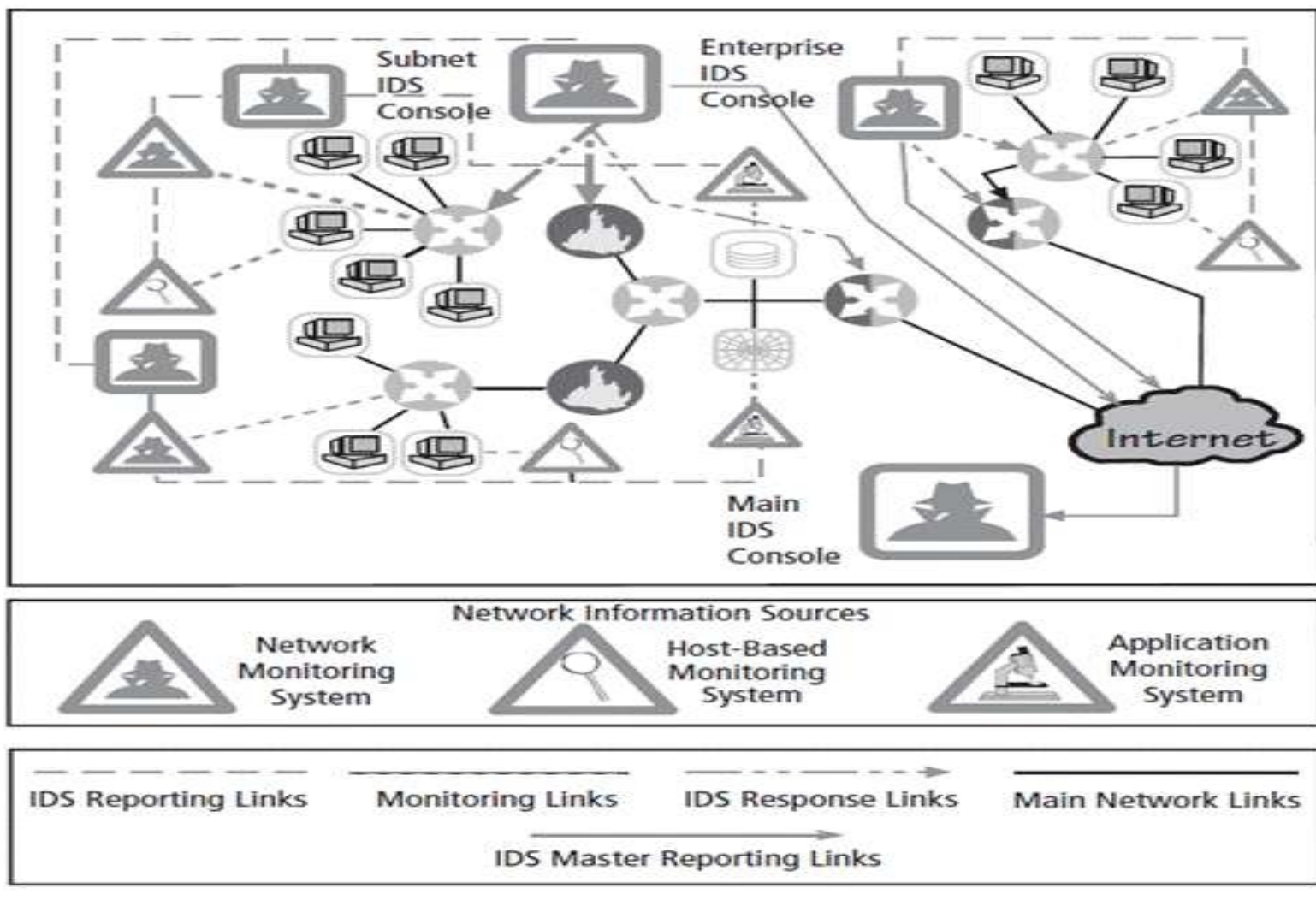


Figure 7-6 Partially distributed IDPS control²²

Source: Adapted from Scarfone and Mell, NIST SP 800-94.

IDPS deployment

- Great care must be taken when deciding where to locate components.
- Planners must select deployment strategy that is based on careful analysis of organization's information security requirements and causes minimal impact.
- NIDPS and HIDPS can be used in tandem to cover individual systems that connect to an organization's network and networks themselves.

Deploying network-based IDPSs

- NIST recommends four locations for NIDPS sensors
 - Location 1: Behind each external firewall, in the network DMZ
 - Location 2: Outside an external firewall
 - Location 3: On major network backbones
 - Location 4: On critical subnets

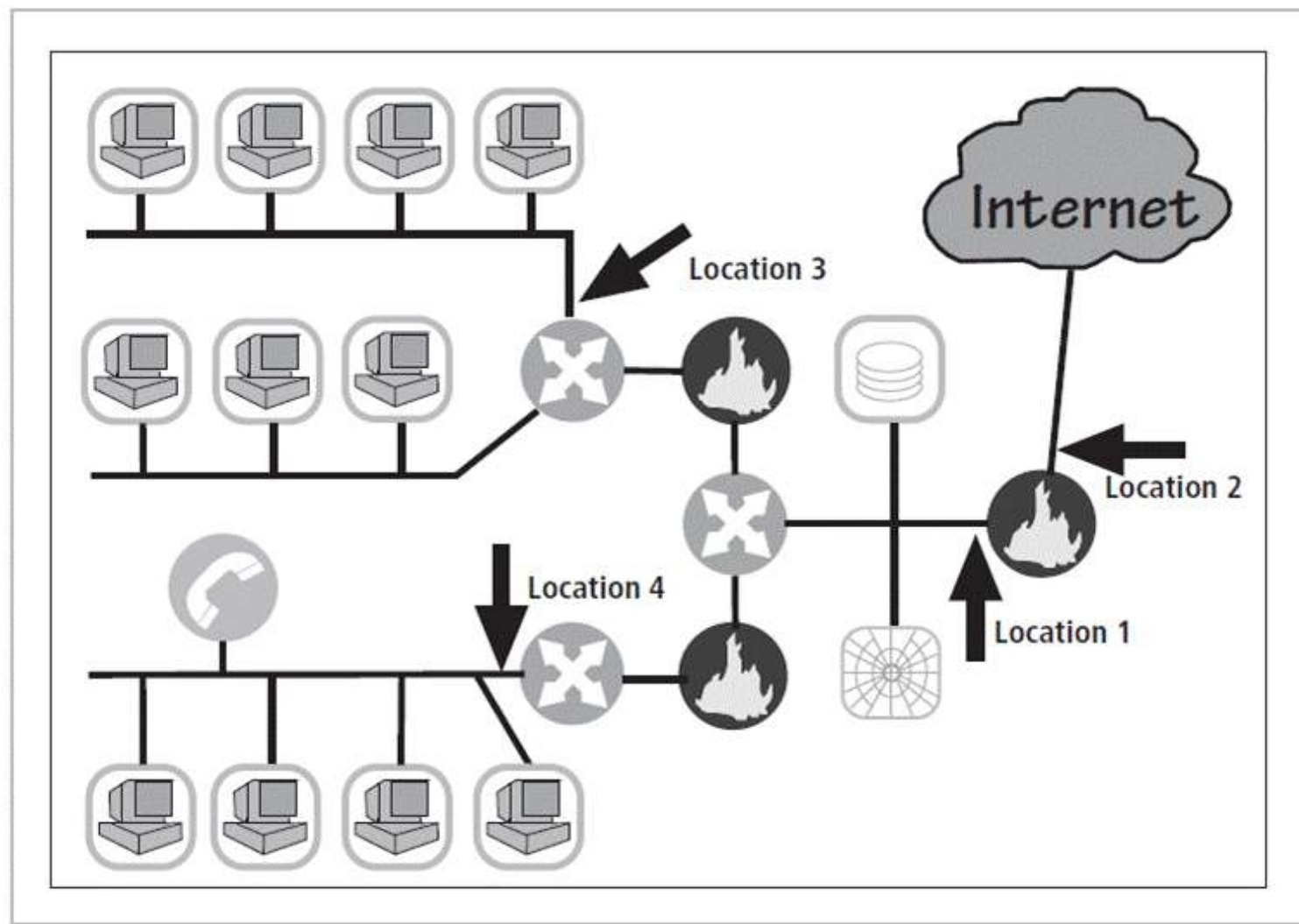


Figure 7-7 Network IDPS sensor locations²³

Source: Adapted from Scarfone and Mell, NIST SP 800-94.

- **Deploying host-based IDPSs**

- Proper implementation of HIDPSs can be a painstaking and time-consuming task.
- Deployment begins with implementing most critical systems first.
- Installation continues until either all systems are installed or the organization reaches planned degree of coverage it will accept.

HONEYPOTS, HONEYNETS, AND PADDED CELL SYSTEMS

- **Honeypots:** decoy systems designed to lure potential attackers away from critical systems
- **Honeynets:** several honeypots connected together on a network segment
- Honeypots are designed to:
 - Divert attacker from accessing critical systems
 - Collect information about attacker's activity
 - Encourage attacker to stay on a system long enough for administrators to document the event and perhaps respond

- **Padded cell system:** protected honeypot that cannot be easily compromised
- In addition to attracting attackers with tempting data, a padded cell operates in tandem with a traditional IDPS.
- When the IDPS detects attackers, padded cell system seamlessly transfers them to a special simulated environment where they can cause no harm—hence the name padded cell.

Advantages

- Attackers can be diverted to targets they cannot damage.
- Administrators have time to decide how to respond to an attacker.
- Attackers' actions can be easily and more extensively monitored, and records can be used to refine threat model and improve system protections.
- Honeypots may be effective at catching insiders who are snooping around a network.

Disadvantages

- Legal implications of using such devices are not well understood.
- Honeypots and padded cells have not yet been shown to be generally useful security technologies.
- An expert attacker, once diverted into a decoy system, may become angry and launch a more aggressive attack against an organization's systems.
- Administrators and security managers need a high level of expertise to use these systems.

TRAP-AND-TRACE SYSTEMS

- Use a combination of techniques to detect an intrusion and trace it back to its source
- Trap usually consists of a honeypot or a padded cell and alarm.
- Legal drawbacks to trap and trace
 - Enticement: act of attracting attention to system by placing tantalizing information in key locations
 - Entrapment: act of luring an individual into committing a crime to get a conviction
 - Enticement is legal and ethical, entrapment is not.

Working of TRAP-AND-TRACE SYSTEMS

- The system sets a trap (such as a decoy service, fake account, or monitored resource).
- When an attacker interacts with the trap, the system records detailed information such as:
 - Source IP address
 - Time and date
 - Type of activity performed
- The trace function follows the activity back through the network to identify the attacker's path.
- Alerts and logs are generated for analysis and response.

ACTIVE INTRUSION PREVENTION

- Active intrusion prevention systems don't just detect suspicious behavior they take action in real time.
- This could include blocking a suspicious IP address, logging out a user, or dropping a network connection.
- The main goal is to reduce damage quickly, minimize exposure time, and give administrators alerts so they can respond immediately.
- This proactive approach is becoming more common because attacks today are fast, automated, and often capable of causing damage within seconds.

- Some organizations implement active countermeasures to stop attacks.
- One tool that provides active intrusion prevention is known as LaBrea.
 - LaBrea works by taking up the unused IP address space within a network.
 - If an address is not currently being used by a real computer or network device, LaBrea will pretend to be a computer at that IP address and allow the attacker to complete the connection request, known as the three way handshake.
 - Once the handshake is complete, LaBrea will change the TCP sliding window size down to a low number to hold the
 - TCP connection from the attacker open for many hours, days, or even months. Holding the connection open but inactive greatly slows down network based worms and other attacks.
 - It allows the LaBrea system time then to notify the system and network administrators about the anomalous behavior on the network.

Scanning and Analysis Tools

There are several categories of scanning and analysis tools. The following are the categories of scanning and analysis tools.

- Port Scanners
- Firewall Analysis Tools
- Operating System Detection Tools
- Vulnerability Scanners
- Packet Sniffers
- Wireless Security Tools

Port Scanners

- Port scanners are tools used by both attackers and defenders to identify the computers that are active on a network, as well as the ports and services active on those computers.
- Can either perform generic scans or those for specific types of computers, protocols, or resources
- The more specific the scanner is, the more useful its information is to attackers and defenders.

OS detection tools

- Ability to detect a target computer's operating system (OS) is very valuable to an attacker.
- Once OS is known, the attacker can easily determine the vulnerabilities to which it is susceptible.
- Many tools use networking protocols to determine a remote computer's OS.

Port number	Protocol
7	Echo
20	File Transfer [Default Data] (FTP)
21	File Transfer [Control] (FTP)
23	Telnet
25	Simple Mail Transfer Protocol (SMTP)
53	Domain Name System (DNS)
80	Hypertext Transfer Protocol (HTTP)
110	Post Office Protocol version 3 (POP3)
161	Simple Network Management Protocol (SNMP)

Table 7-1 Commonly Used Port Numbers

- **Firewall analysis tools**
- Helps in understanding and discovery of firewall rules and assist the administrator in analyzing the rules to determine exactly what they allow and what they reject.
- Administrators who feel wary of using the same tools that attackers use should remember:
 - User intent dictates how gathered information will be used.
 - To defend a computer or network well, administrators must understand ways it can be attacked.
- A tool that can help close an open or poorly configured firewall will help the network defender minimize risk from attack.

Vulnerability scanners

- Active vulnerability scanners examine networks for highly detailed information and initiate traffic to determine security holes.
- Passive vulnerability scanners listen in on network and identify the vulnerable versions of both server and client software.
- Passive vulnerability scanners have the ability to find client-side vulnerabilities typically not found in active scanners.

Packet sniffers

- A network tool that collects copies of packets from the network and analyzes them.
- Can provide network administrator with valuable information for diagnosing and resolving networking issues
- In the wrong hands, a sniffer can be used to eavesdrop on network traffic.
- To use packet sniffers legally, an administrator must be on a network that the organization owns, be under direct authorization of owners of the network, and have knowledge and consent of the content's creators.

Wireless Security Tools

- An organization that spends its time securing a wired network while ignoring wireless networks is exposing itself to a security breach.
- Security professionals must assess the risk of wireless networks.
- A wireless security toolkit should include the ability to sniff wireless traffic, scan wireless hosts, and assess the level of privacy or confidentiality afforded on the wireless network.

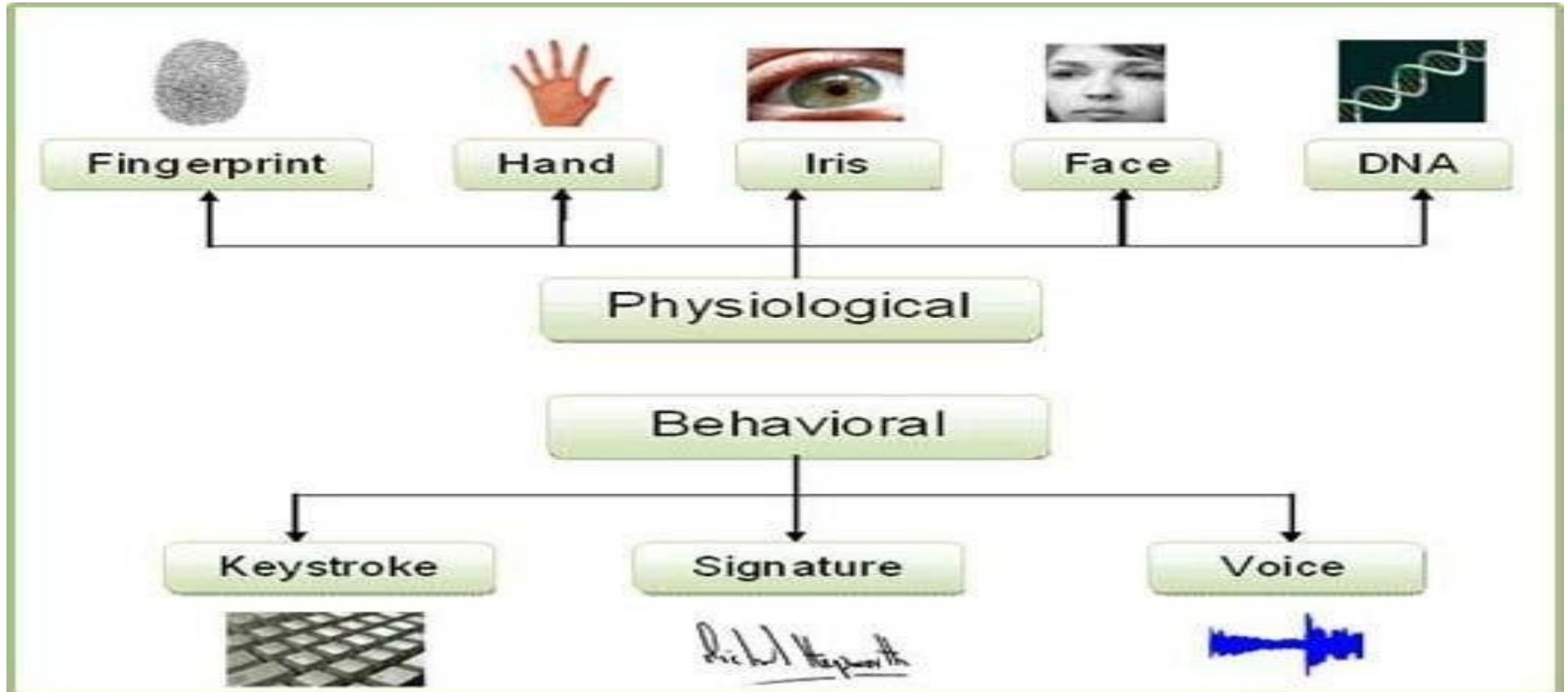
Biometric Access Controls

- Biometric access controls authenticate users based on unique physical or behavioral characteristics such as fingerprints, facial features, iris patterns, or voice recognition.
- These systems are widely used for secure access to devices, buildings, and systems.
- This type of access relies on pattern recognition, comparing the collected information with previously stored data in a database. This is made possible because each human being has distinct and unique traits such as fingerprints, voice, or iris patterns, among others.

Example:

Using facial recognition to enter a secured office area.

Types of Biometric



Effectiveness of Biometrics

- **Superior Security:** Biometrics are hard to duplicate, steal, or lose, making unauthorized access difficult compared to keys or passwords.
- **High Accuracy:** Relying on unique traits offers high verification accuracy, though 100% accuracy isn't possible; systems manage false acceptances/rejections.
- **Non-Repudiation:** Ensures recorded access events are accurate, as only the genuine user could have granted entry.
- **Speed & Convenience:** Provides quick, frictionless access, eliminating need to remember/carry credentials.
- **Multi-Modal Benefits:** Combining methods (e.g., face + fingerprint) significantly boosts security.

Acceptability of Biometrics

- **High & Growing:** Acceptance is strong and increasing due to familiarity (phones/laptops) and proven benefits in corporate, financial, and government sectors.
- **Privacy Concerns:** A key hurdle; users worry about data breaches, misuse, or potential for identity theft if biometric templates are compromised.
- **Implementation Costs:** Initial setup, hardware, and infrastructure upgrades can be significant.
- **User Experience:** Generally positive due to convenience, but false rejections can cause frustration; systems must balance security needs with user flow.
- **Regulatory Landscape:** Data protection laws influence how biometric data is collected, stored, and used, impacting adoption